
Bitcoin Cold Storage, Multisig Backups, Air-Gapped Signing & Inheritance

A Brainstorm on Secure Key Storage and Robust Estate Planning

October 2026

Informed by MrHodl's cold-storage thread, Yeti 2.0, EntropyLab,
collaborative custody research, Liana/Miniscript, and Bitcoin Core's official tutorials

Bitcoin Cold Storage Brainstorm

0. The Mental Model That Frames Everything

Cold storage is a **process, not a device**. Separate three jobs that people conflate into one gadget:

1. **Key generation** — where entropy comes from (weak entropy means everything downstream is theater)
2. **Backup** — the durable recovery object (steel, paper, optical media)
3. **Signing** — the replaceable tool you use to spend

The backup is the long-lived object; the signer is disposable. "My bitcoin is on my hardware wallet" is the wrong sentence — the hardware wallet is just the current signing tool. Every architecture idea below is a variation on assigning different media, locations, and people to these three jobs.

1. What the Reference Implementations Teach Us

Yeti 2.0 — the "trusted artifact is text" model

- Two dedicated refurbished laptops: one online running a full archival Bitcoin Core node, one permanently air-gapped booting a live Ubuntu USB with networking and swap disabled.
- Seven key wallets created on the offline machine, assembled into a 3-of-7 `wsh(sortedmulti)` descriptor.
- Each key burned onto an archival DVD together with the watch-only wallet and the guide itself; the seven DVDs are geographically distributed in non-descript envelopes.
- The scripts are intentionally identical to Bitcoin Core's official multisig/offline-signing tutorials — the whole thing is diffable line-by-line against the most scrutinized software in Bitcoin. It ships no software; it is a tutorial, not an application.
- Mandatory rehearsal: three test transactions exercising all seven keys before real funds touch the vault.

EntropyLab — the verification layer

- Browser-based calculator accepting dice rolls, coin flips, hex entropy, BIP39 seeds, xprvs, WIF keys; derives seeds, xpubs, descriptors, and Bitcoin Core-compatible watch-only `wallet.dat` files.
- Inspects PSBTs for repeated ECDSA nonces, verifies Jade anti-exfil transcripts, checks signatures against RFC 6979, exports BIP 388 wallet policies, and runs host-environment sanity checks.
- This is the "trust but verify" companion: bring your own entropy (dice), it proves the derivation, and it can emit a signing or watch-only Core wallet from the *same* root as your steel backup.

The combined lesson: entropy from dice + a verifiable calculator + Core's reference scripts + air-gapped live-USB signing + optical/steel backups + mandatory rehearsal. No vendor anywhere in the chain.

2. Vault Architecture Ideas (the Quorum Design Space)

A. The classic deep-cold vault — 3-of-7 Yeti-style. Tolerates 4 lost keys; requires 3 compromised locations to steal. Best for pure savings in the \$10k–\$5M range. Weakness: on-chain fingerprint (a 3-of-7 is conspicuous), and heirs face a coordination problem.

B. Tiered custody pyramid. Don't put everything in one vault:

- **Spending (hot):** phone wallet, small amounts
- **Checking (warm):** 2-of-3 collaborative custody (Casa/Unchained/Nunchuk) — you hold majority keys, the provider holds a recovery backstop and can never move funds unilaterally
- **Savings (cold):** DIY 2-of-3 or 3-of-5 on hardware signers with Sparrow
- **Generational (deep cold):** Yeti-style Core vault or timelocked Miniscript setup

Different quorums, different vendors, different failure modes — correlated failure (one signer bug, one compromised coordinator) can't take everything.

C. Decaying multisig (the elegant inheritance primitive). A 3-of-5 that decays to 2-of-5 after 18 months of inactivity, then 1-of-5 after 3 years — expressed in Miniscript with relative timelocks. While you're alive and refreshing the timelocks, full security; after you're gone, the threshold drops on its own and heirs need fewer keys. Liana pioneered this: recovery paths enforced on-chain by Bitcoin itself, with no third party to trust. Nunchuk 2.0 ships the same idea commercially — after a configurable timelock, the platform key drops out of the signing requirement automatically, so inheritance executes even if the company disappears.

D. Geographically distributed heterogeneous signers. In a 3-of-5, use five *different* signer types (Coldcard, SeedSigner, Jade, a Core offline laptop, a Trezor) in five locations. Vendor diversity means no single firmware bug, supply-chain attack, or secure-element vulnerability is catastrophic. All major coordinators support mixed-device quorums.

3. Air-Gapped Signing Device Ideas

E. The SeedSigner model as a philosophy. ~\$50 of generic hardware (Pi Zero 1.3 — no WiFi/BT chip, so the air gap is *physical*), stateless (keys live in RAM only, wiped on power-off), QR-only communication in both directions, fully open source with reproducible builds. Statelessness is the killer feature: a stolen or seized unit is a worthless bare Pi, and one device can sign for many cosigners.

F. QR over USB where possible. Yeti uses USB sticks for PSBT transfer only because Core lacks QR signing — and explicitly notes USB is inferior to QR for limiting data flow, transfer frequency, and out-of-band verification. For any signer you design or choose: animated QR (UR/BCUR2) one-way video channel beats removable media.

G. The "burner signer" pattern. A cheap laptop that boots a live USB, signs, and is wiped — no persistent state at all (exactly Yeti 2.0's offline machine: nothing is ever written to its internal drive; keys come off DVDs per session). The signing environment is ephemeral; only the backup media persist. This inverts the hardware-wallet model — the device holds *nothing*, ever.

H. PSBT verification as a first-class ritual. Before signing: decode the PSBT on a *second* independent tool (EntropyLab, Sparrow, `decodepsbt`), confirm outputs/amounts/fee, check change outputs belong to your wallet, check for nonce reuse. After signing: re-verify before broadcast. This catches malicious coordinators and address-swap malware — the realistic attack on air-gapped setups.

4. Backup & Key-Storage Ideas

I. The descriptor is the forgotten backup. Everyone backs up seeds; almost nobody backs up the *wallet descriptor* — and without it, a multisig with a lost key is unrecoverable even with the remaining seeds, because you can't reconstruct which xpubs/derivations formed the quorum. Rule: every key backup location also gets a copy of the descriptor (privacy-sensitive, not spend-enabling). Yeti does this right — every DVD carries key + watch-wallet + guide.

J. Media layering per threat.

- **Steel** (fire/flood, decades) for seeds/passphrases — crude is the point: no firmware, no vendor, no USB standard
- **Archival optical** (DVD/M-Disc class) for wallet files + descriptors + recovery instructions — refresh roughly every 7 years
- **Encrypted digital** (AES-256-GCM JSON, PBKDF2 — the EntropyLab Journal model) for convenience copies
- **Paper** with NATO phonetic transcription + every-5th-word checksum for human-readable error correction (the original YetiCold trick)

K. Split knowledge, not just keys. Shamir (SLIP-39) splits *one* key — fine for redundancy, but the reconstructed secret is still a single point of failure at use-time. Multisig splits *spending authority* and never reconstructs anything. Rule of thumb: Shamir for backing up a passphrase or a single-signer seed; multisig for the vault itself.

L. Decoy & duress layers. BIP39 passphrases give free hidden wallets: real vault under passphrase A, plausible-deniability decoy (with a believable balance) under passphrase B. A small decoy single-sig serves as the "give them something" layer under physical coercion. The \$5-wrench defense is really *distribution*: 3-of-7 across 7 locations means no single location's compromise matters.

5. Inheritance Architectures (the Hard Problem)

Core tension: heirs need access *eventually*, must not have access *now*, and you can't trust that any company, lawyer, or website exists in 30 years.

M. On-chain timelock inheritance (most trustless). Liana's simple template: your key spends anytime; the beneficiary's key activates after ~15 months of wallet inactivity, enforced by Bitcoin consensus. Stack multiple recovery paths: family 2-of-3 after 1 year, professional custodian "Safety Net" after 15 months. The catch: you must *refresh* — send coins to yourself before each timelock expires, paying fees each time. A dead-man's switch where *you* wind the clock.

N. Distributed-key inheritance (no timelock maintenance). 3-of-5 where you hold 3 keys, and two "inheritance keys" live with family/attorney/safe-deposit — useless alone today, but after death the heirs combine their 2 with any 1 of yours (retrieved by your executor per your instructions). Nunchuk's Honey Badger tiers formalize this. Variant: each family member holds a key that alone does nothing — no single heir can be targeted or coerced.

O. Collaborative custody as inheritance executor. Casa's 6-month uncontested claim (no KYC, recipient email); Unchained's document-heavy Inheritance Protocol with concierge walkthrough for heirs plus transfer-on-death probate bypass. The right mental model: you're renting a *recovery process for your heirs*, not custody for yourself.

P. The "letter + rehearsal" layer (free, most skipped). Whatever the technical scheme: a sealed letter to the executor describing the structure (not the seeds), where pieces live, who to call, and which open-source tools to use — plus an actual drill. The most common inheritance failures are mundane: untested recovery, seed stored with the device, everything concentrated with one person. Write down the plan, not the seed; run a small dry-run with the heirs.

6. Outside-the-Box Ideas

Q. The "guardian quorum" vault. 2-of-4: you, spouse, a family friend who doesn't know what the envelope contains, a safety-deposit box. Any two — but combinations designed so no pair existing today (besides you + spouse) can collude without triggering notice.

R. Anti-exfil by construction. Signers supporting sign-to-contract / anti-exfil protocols (Jade, Coldcard) make the signature itself prove the nonce wasn't covertly chosen to leak the key — verify transcripts independently with EntropyLab. Paranoid tier: dice-generated entropy; never let a device's RNG near your seed at all.

S. The verifiable-tutorial signing kit (Yeti philosophy, productized). A live-USB image whose *entire* signing logic is a short shell script diffable against Bitcoin Core's docs, booted on any generic laptop, networking hard-disabled, keys loaded from optical media, PSBTs in/out on a one-way QR bridge. The security claim isn't "trust us" — it's "diff 40 lines."

T. Progressive decentralization of your own custody. Year 1: collaborative custody 2-of-3 while you learn (you can always exit — Casa publishes sovereign-recovery docs, Unchained open-sourced Caravan as the escape hatch). Year 2: migrate to DIY 3-of-5 with diverse signers. Year 3: add timelocked decaying paths for inheritance. Each stage, you shed a trust assumption only after rehearsing the next one.

U. Multisig-as-canary. A tiny "tripwire" UTXO in a separate single-sig whose seed is stored in your house. If someone physically searches and finds it, they'll sweep the decoy — and the on-chain movement is your intrusion alarm (watch it with your own node over Tor).

V. MuSig2/Taproot when it matures. Taproot multisig makes the quorum indistinguishable from single-sig on-chain — fixing Yeti's known privacy leak (a visible 3-of-7 fingerprints you). Watch Nunchuk's MuSig2 beta; don't build the deep vault on it until signing-device support broadens.

7. Failure-Mode Checklist (What Actually Kills Setups)

Failure mode	Mitigation
Lost descriptor	Multisig unrecoverable despite holding seeds — back the descriptor up everywhere
Untested recovery	Rehearse with real small transactions before funding (Yeti mandates 3 test spends covering all 7 keys)
Seed + device co-located	Geographic separation is the entire point
Timelock lapse	Calendar reminders + fee budget for refreshes; overlapping recovery paths as backup
Single-vendor monoculture	Mix signer hardware and coordinator software
Trusted setup help	A moderately technical person should follow the guide <i>alone</i> — a helper is an attack vector
PSBT signed blind	Verify before and after, on a second tool

8. Three Concrete Reference Stacks

Tier	Vault	Signers	Backup	Inheritance
Minimal (~\$100)	2-of-3 Sparrow multisig	2× SeedSigner (DIY) + 1 mobile key	Steel ×3 + descriptor ×3	Letter + key with attorney
Robust (~\$500)	Liana decaying 2-of-3 → 1-of-3 @ 15 months	Coldcard Q + Jade + SeedSigner	Steel + encrypted JSON + descriptor in 3 locations	Timelocked heir key (trustless) + rehearsal
Paranoid (~\$750, Yeti-class)	Core 3-of-7, full archival node, Tor	Air-gapped live-USB laptop	7 archival DVDs (key + descriptor + guide each), 7 locations	Distributed envelopes + executor letter; optionally wrap in Liana-style timelocks later

The unifying principle: distribute trust across media, locations, vendors, people, and time — and make every recovery path one you've actually walked through at least once with real (small) money.

Sources

- MrHodl, "Cold storage is a process" thread — x.com/mrhodl/status/2106514934570123438
- Yeti 2.0 — secure air-gapped Bitcoin Core multisig guide — github.com/bowlarbear/yeti-2.0
- YetiCold (original) — github.com/JWWeatherman/yeticold
- EntropyLab (oogabooga team) — [entropy / derivation / PSBT verification calculator](#)
- Liana (Wizardsardine) — [Miniscript timelocked recovery wallet](#)
- SeedSigner — [stateless air-gapped DIY signing device](#)
- Casa / Unchained / Nunchuk — [collaborative custody and inheritance programs](#)
- Bitcoin Core official multisig & offline-signing tutorials